Care Access Navigator

Compliance 1 — Task 4: Documentation & Reporting

Documentation package with templates, version control and distribution; management compliance status report; records management with retention schedule and access controls; KPI monitoring and reporting framework

Prepared by:	Akhila Chennamaneni, GRC Analyst (author)
Organization:	HealthLine Regional Medical Center — Care Access Navigator (CAN)
Companion file:	Care_Access_Navigator_Compliance1_Tracker.xlsx (KPI Monitor, Remediation, Evidence Register, Retention Schedule, Document Register, Dashboard)
Date:	October 13, 2026

1. Documentation Package

Every compliance document in the program follows one template and one control process, so readers always know whether they hold the current, approved version and who may receive it.

1.1 Standard document template

Section	Content	Mandatory
Header block	Document ID, title, version, owner, approver, effective date, next review, classification	Yes
Version history	Version, date, author, change summary, approved by	Yes
Purpose / scope	Why the document exists; systems, people and data covered	Yes
Body	Policy statements, procedure steps, or report content (numbered)	Yes
Roles and responsibilities	RACI or named roles	Policies, procedures
References	Regulatory citations (HIPAA, PCI DSS) and related documents	Yes
Footer	Title, page X, classification label, 'Uncontrolled when printed'	Yes

1.2 Document ID scheme

Pattern	Meaning	Example
CAN-POL-xx-nnn	Policy (xx = domain: AC access, LOG logging, IR incident)	CAN-POL-AC-001
CAN-PRC-xx-nnn	Procedure implementing a policy	CAN-PRC-AC-002
CAN-COMP-xxx-nnn	Program-level compliance document	CAN-COMP-PLN-001
CAN-AUD-yyyy-nn	Audit report	CAN-AUD-2026-01
CAN-RPT-STS-Qn	Periodic status report	CAN-RPT-STS-Q4

1.3 Version control procedure

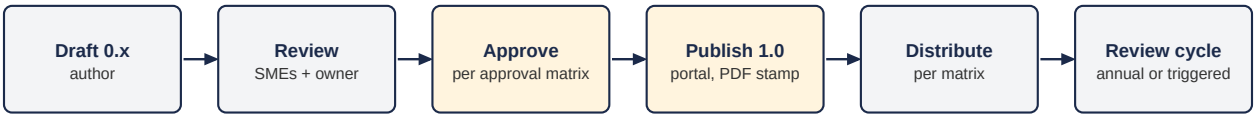

Figure 1. Document lifecycle and version control.

- Major version (2.0) for changes in requirements or scope; minor (1.1) for clarifications; drafts are 0.x and never distributed outside the review group.
- The policy portal (versioned SharePoint library) is the single authoritative source; check-out/check-in prevents parallel edits and every save is retained.
- On approval the PDF is stamped with version and effective date; the previous version moves to a read-only archive (kept 6 years, HIPAA §164.316(b)(2)(i)).
- Annual review is scheduled from the 'Next review' date in the document register; a regulatory change, audit finding or incident triggers an earlier review.

1.4 Distribution procedure

Class	Examples	Who may receive	Channel	Ack.
Public	Notice of Privacy Practices	Anyone	Website, front desk	—
Internal	Policies, procedures, training plan	All workforce; vendors as needed	Policy portal / LMS	Annual attestation in LMS
Confidential	Audit reports, status reports, incident records	Named roles (committee, Board, owners)	Portal with role-based access; encrypted email	Read receipt
Restricted	Evidence packs containing system details or PHI	GRC, Internal Audit, Privacy/Security Officer	Evidence repository only	Access logged

1.5 Document register (package contents)

Doc ID	Title	V	Owner	Next review	Class.
CAN-COMP-RA-001	Compliance Requirements Analysis	1.0	GRC Analyst	2027-10-13	Internal
CAN-COMP-PLN-001	Compliance Program Plan FY2027	1.0	CCO	2027-10-01	Internal
CAN-COMP-GOV-001	Compliance Governance Charter & Communication Plan	1.0	CCO	2027-11-01	Internal
CAN-POL-AC-001	Access Control and Identity Management Policy	1.0	Security Officer	2027-12-01	Internal
CAN-PRC-AC-002	Quarterly User Access Review Procedure	1.0	IAM Analyst	2028-01-01	Internal
CAN-TRN-PLN-001	Compliance Training Plan	1.0	Privacy Officer	2028-01-01	Internal

Doc ID	Title	V	Owner	Next review	Class.
CAN-AUD-2026-01	Internal Compliance Audit Report (IAM & monitoring)	1.0	GRC Analyst	Follow-up Jan 2027	Confidential
CAN-RPT-STS-Q4	Compliance Status Report Q4 2026	1.0	CCO	Quarterly	Confidential
CAN-REC-RET-001	Records Retention Schedule	1.0	GRC Analyst	2027-11-01	Internal
CAN-PLB-IR-001	Incident Response Playbook	1.0	Security Officer	2027-10-08	Confidential
CAN-LGL-OBL-001	Compliance Obligations Matrix	1.0	Privacy Officer	2027-11-01	Internal

2. Compliance Status Report — Q4 2026

To	From	Date	Class	Doc ID
Program Sponsor (COO); Board Audit & Compliance Committee	Chief Compliance Officer (prepared by GRC Analyst)	October 20, 2026	Confidential	CAN-RPT-STS-Q4

Executive summary

Overall status: AMBER. HealthLine's Care Access Navigator now has a defined compliance program for HIPAA and PCI DSS, enforceable governance guardrails in Azure (100% compliant), and strong role-based access (every workforce account holds exactly one approved role). The first internal audit, however, found that **authentication hardening and log retention lag behind requirements**: MFA is not enforced, account lockout is off, and central logs are kept 90 days instead of 12 months. Of 11 key indicators, **6 are green, 3 red, 2 not yet measurable**. Three High findings have owners and target dates; none is overdue. **Two decisions are requested** (below).

Scorecard

Area	Framework	Status	Comment
Governance and policy	HIPAA 164.308(a)(1); PCI 12	**Green**	Program plan, charter, Access Control Policy approved
Authorization / least privilege	HIPAA 164.308(a)(4); PCI 7	**Green**	9/9 accounts least-privilege; client scopes enforced
Authentication (MFA, lockout, passwords)	HIPAA 164.312(d); PCI 8	**Red**	F-01, F-02, F-04 open
Logging and monitoring	HIPAA 164.312(b); PCI 10	**Amber**	Alerting works (MTTD 7.5 min); retention gap F-03; review records F-05
Transmission security	HIPAA 164.312(e); PCI 4	**Green**	TLS 1.2 enforced by policy; lab IdP exception F-06
Asset and cloud governance	HIPAA 164.310(d); PCI 12.5	**Green**	100% tagging; 7 deny guardrails
Training	HIPAA 164.530(b); PCI 12.6	**Pending**	Rollout starts March 2027

Key findings

ID	Finding	Rating	Owner	Target
F-01	MFA not enforced for privileged / CDE access	High	IAM Analyst	2026-11-06
F-02	Account lockout (brute-force protection) disabled	High	IAM Analyst	2026-10-23
F-03	No 12-month central log retention	High	Security Officer	2026-11-30
F-04	Password length 10 / history 3 below PCI minimum	Medium	IAM Analyst	2026-10-23
F-05	No completed access review / daily log review records	Medium	IAM / Security Analyst	2026-12-15

ID	Finding	Rating	Owner	Target
F-06	Identity provider over HTTP in lab	Low	IT Support	2027-01-31

Recommendations and decisions requested

#	Recommendation	Benefit	Decision needed
1	Enforce MFA and lockout in Keycloak within 3 weeks (F-01, F-02, F-04)	Closes the largest credential-compromise exposure; meets PCI 8.3/8.4	None — within IAM budget
2	Fund a central log store with 12-month retention (F-03)	Meets PCI 10.5.1 and HIPAA audit-control expectations; supports investigations	**Approve ~$5–15/month** log-platform spend
3	Launch quarterly access reviews and daily log-review checklist (F-05)	Produces the operating evidence auditors require	Managers' time: ~30 min/quarter each
4	Accept lab-only HTTP for the IdP until production TLS (F-06)	Avoids lab cost; no production exposure	**Formal risk acceptance** by Program Sponsor until 2027-01-31

Next report: January 2027 (after follow-up audit).

3. Records Management

Compliance records must be retained long enough to prove compliance, protected from unauthorized access or alteration, and disposed of securely when no longer required. The schedule below is maintained in the tracker workbook (sheet *Retention Schedule*).

Record type	Driver	Retention	Owner	Disposal
Compliance policies, procedures (all versions)	HIPAA 164.316(b)(2)(i)	6 years from last effective date	GRC Analyst	Secure delete after review
Risk analyses and risk register	HIPAA 164.316(b)(2)(i); 164.308(a)(1)	6 years	GRC Analyst	Secure delete
Audit reports and evidence packs	HIPAA 164.316; Internal Audit standards	6 years	Internal Audit	Secure delete
Security audit logs (CDE)	PCI DSS 10.5.1	12 months (3 months online)	Security Officer	Automatic expiry
Security audit logs (ePHI systems)	HIPAA 164.312(b) (policy-set)	6 years (summaries); 12 months raw	Security Officer	Automatic expiry
Access requests, reviews, certifications	HIPAA 164.308(a)(4); PCI 7.2.4	6 years	IAM Analyst	Secure delete
Training records and attestations	HIPAA 164.530(b)(2), 164.530(j)	6 years	Privacy Officer	LMS purge

Record type	Driver	Retention	Owner	Disposal
Incident and breach records, notifications	HIPAA 164.530(j); 164.414 burden of proof	6 years	Privacy Officer	Secure delete
Business associate agreements	HIPAA 164.316, 164.504(e)	6 years after termination	Vendor Manager	Secure delete
Medical records (EHR)	NY 10 NYCRR 405.10	6 years after discharge, or 3 years after age 18, whichever is longer	HIM Director	NIST SP 800-88 purge
PCI SAQ, AOC, ASV scan reports	PCI DSS 12.4, 11.3.2	3 years (policy-set)	Security Officer	Secure delete

Access controls for records

Control	Implementation
Role-based access	Repository permissions mirror the RBAC model: owners edit, defined roles read, everyone else denied; reviewed in the quarterly access review
Integrity	Evidence stored write-once (immutability policy) with SHA-256 hashes in the evidence register
Encryption	At rest (platform-managed keys, CMK planned) and in transit (TLS 1.2+, enforced by Azure Policy)
Access logging	All access to Confidential/Restricted records logged and retained per PCI 10.5.1
Legal hold	Privacy Officer or counsel can suspend disposal for any record linked to an investigation, audit or litigation; holds are listed in the register and reviewed quarterly
Disposal	Records past retention are reviewed by the owner, then destroyed per NIST SP 800-88 with a certificate of destruction kept 6 years

4. Monitoring System and Key Performance Indicators

Monitoring is implemented in two layers: **automated control monitoring** in Azure (Azure Policy compliance, Azure Monitor alerts, Keycloak events) and a **KPI workbook** that turns those signals into indicators with targets, thresholds and automatic RAG status. KPIs below marked as measured use real values taken from the live environment.

ID	KPI	Target	Current	Status	Source / frequency
K-01	Asset tagging compliance	100%	100%	**Green**	Azure Resource Graph; daily (azure policy)
K-02	Guardrail policy compliance	100%	100%	**Green**	Azure Policy; daily
K-03	Least-privilege accounts	100%	100%	**Green**	Keycloak extract; quarterly
K-04	MFA coverage (privileged + CDE)	100%	0%	**Red**	Keycloak flows; monthly
K-05	Security alert rules enabled	100%	100%	**Green**	Azure Monitor; weekly
K-06	Log retention vs requirement	100%	24.7%	**Red**	Log platform; monthly
K-07	Audit test pass rate	90%	53.3%	**Red**	Audit CAN-IA-2026-01; per audit
K-08	High findings overdue	0 count	0 count	**Green**	Remediation tracker; weekly
K-09	Mean time to detect (MTTD)	15 min	7.5 min	**Green**	Incident records; per incident
K-10	Workforce training completion	95%	—	**Pending**	LMS; monthly
K-11	Access reviews completed on time	95%	—	**Pending**	Review tickets; quarterly

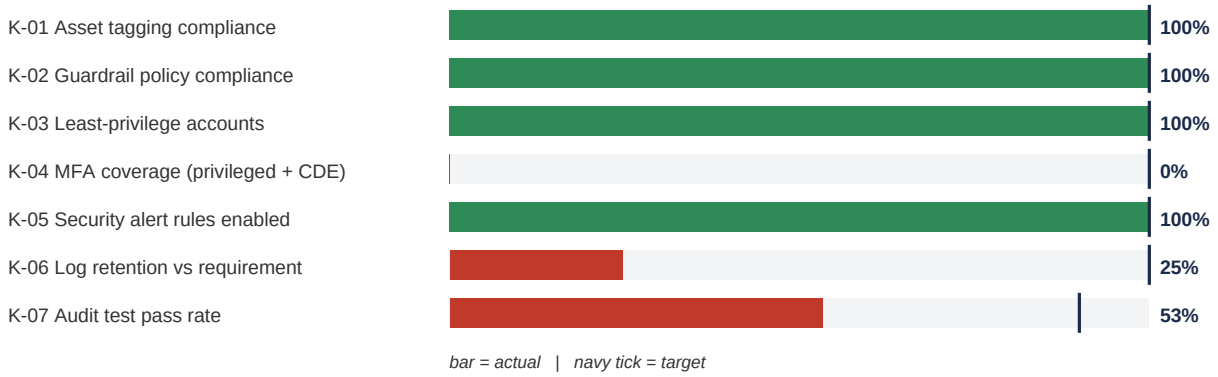

Figure 2. Percentage KPIs: current value vs target (navy tick).

Reporting framework

Level	Audience	Content	Frequency	Mechanism
Operational	Control owners, Security Analyst	Alerts, failed policy evaluations, overdue actions	Real-time / weekly	Azure Monitor email; tracker Remediation sheet
Management	Compliance & Privacy Committee	KPI dashboard, findings status, exceptions	Monthly	Tracker Dashboard sheet + committee pack

Level	Audience	Content	Frequency	Mechanism
Executive	Program Sponsor, Board committee	Status report (Section 2), top risks, decisions	Quarterly	CAN-RPT-STS-Qn
Regulatory	HHS OCR, acquirer, NY AG	Breach notices, SAQ/AOC, ASV results	As required	Formal submission

Escalation thresholds

- Any KPI **Red** for two consecutive months → corrective action plan to the committee.
- Any High finding **overdue** → Program Sponsor decides: extra resources or formal risk acceptance.
- Any suspected breach → Privacy Officer immediately (60-day notification clock, Task 5).

Summary

The documentation package standardizes every compliance document's template, numbering, versioning and distribution; the Q4 status report gives management a concise, decision-oriented view; the retention schedule and records controls meet HIPAA's six-year rule and PCI DSS log retention; and the KPI workbook provides a working monitoring system with live RAG formulas and a dashboard.